

(a) MODELO DE ENCUESTA INTEGRAL MARGA-ENS

Encuesta sobre Indicadores y Métricas de Ciberseguridad

Marco MARGA-ENS — Aplicación Organizativa

Esta encuesta forma parte de un ejercicio nacional de madurez ilustrada: medir, comprender y mejorar, en ese orden. Si en algún momento siente la tentación de responder “no aplica”, pregúntese si no será, en realidad, “no hemos llegado todavía”.

0. INFORMACIÓN GENERAL DE LA ORGANIZACIÓN

0.1. Identificación básica

1. Tipo de entidad
2. ☐ Administración General del Estado
3. ☐ Administración autonómica
4. ☐ Administración local / entidad instrumental
5. ☐ Empresa pública
6. ☐ Empresa privada (regulada por ENS/NIS2)
7. ☐ Empresa privada (no regulada, pero voluntariamente alineada)
8.
☐ Otro (especificar): _____
9.
Sector principal de actividad
10. ☐ Administración pública
11. ☐ Sanidad
12. ☐ Educación / Universidades
13. ☐ Energía
14. ☐ Transporte y logística
15. ☐ Finanzas / seguros
16. ☐ Telecomunicaciones / TIC
17. ☐ Industria / OT
18.
☐ Otros servicios (especificar): ____
19.
Tamaño aproximado (equivalente a personal empleado)
20. ☐ < 50 personas
21. ☐ 50 – 249
22. ☐ 250 – 999
23. ☐ 1 000 – 4 999
24.
☐ ≥ 5 000
25.
Rol de la persona que responde
26. ☐ CISO / Responsable de Seguridad de la Información
27. ☐ CIO / Responsable TIC

28. ☐ Responsable de Compliance / Riesgos

29. ☐ Dirección General / Gerencia

30. ☐ Otro (especificar): _____

☐ Otro (especificar): _____

Sector principal de actividad

☐ Otros servicios (especificar): ____

Tamaño aproximado (equivalente a personal empleado)

☐ $\geq 5\,000$

Rol de la persona que responde

1. GOBERNANZA, ENS Y ADECUACIÓN

1.1. Alcance y categorización ENS

31. ¿La organización tiene definido formalmente el alcance de los sistemas sujetos al ENS?
32. ☐ Sí, formalmente documentado y aprobado
33. ☐ Sí, pero de forma parcial o desactualizada
34. ☐ En elaboración
35. ☐ No, todavía no
36. ¿Se han categorizado los sistemas según ENS (básico, medio, alto) en función de las dimensiones de seguridad?
37. ☐ Sí, todos los sistemas relevantes
38. ☐ Sí, pero sólo los sistemas más críticos
39. ☐ En proceso de categorización
40. ☐ No se ha realizado categorización formal
41. Aproximadamente, ¿qué porcentaje de sistemas críticos están correctamente categorizados según ENS?
42. ☐ 0–25 %
43. ☐ 26–50 %
44. ☐ 51–75 %
45. ☐ 76–95 %
46. ☐ 96–100 %
47. ☐ No se dispone de esta información
- ☐ No, todavía no
- ¿Se han categorizado los sistemas según ENS (básico, medio, alto) en función de las dimensiones de seguridad?
- ☐ No se ha realizado categorización formal
- Aproximadamente, ¿qué porcentaje de sistemas críticos están correctamente categorizados según ENS?

1.2. Política y organización de la seguridad

48. ¿La organización dispone de una Política de Seguridad de la Información alineada con el ENS y aprobada por la Alta Dirección?

49. ☐ Sí, alineada explícitamente con ENS

50. ☐ Sí, pero sin referencia explícita al ENS

51. ☐ En fase de elaboración/actualización

52.

☐ No existe política formal

53.

Con respecto a la organización de la seguridad (comités, roles, responsables):

54. ☐ Existe un CISO o rol equivalente designado formalmente

55. ☐ Existe un órgano colegiado de seguridad (comité, comisión, etc.)

56. ☐ Las responsabilidades están documentadas y comunicadas

57. ☐ Existen prácticas, pero sin formalización documental

58.

☐ No existe estructura formal de seguridad

59.

¿Con qué frecuencia se revisa y actualiza la Política de Seguridad?

☐ Al menos una vez al año

☐ Cada 2–3 años

☐ De forma ad hoc, ante cambios relevantes

☐ No consta revisión programada

☐ No existe política formal

Con respecto a la organización de la seguridad (comités, roles, responsables):

☐ No existe estructura formal de seguridad

¿Con qué frecuencia se revisa y actualiza la Política de Seguridad?

- ☐ Al menos una vez al año

- ☐ Cada 2–3 años

- ☐ De forma ad hoc, ante cambios relevantes

- ☐ No consta revisión programada

1.3. Declaración de Aplicabilidad y medidas ENS

60.

¿Existe una Declaración de Aplicabilidad (DoA) ENS aprobada?

☐ Sí, para todos los sistemas en alcance

☐ Sí, pero solo para algunos sistemas

☐ En elaboración

☐ No

61.

Indique el estado de implantación de las medidas ENS recogidas en la DoA:

☐ ≥ 80 % implantadas

☐ 60–79 %

☐ 40–59 %

☐ < 40 %

☐ No se dispone de evaluación consolidada

62.

¿Se realiza seguimiento periódico al cumplimiento de la DoA?

☐ Sí, con indicadores y evidencias documentadas

☐ Sí, pero de forma cualitativa y no estructurada

☐ Ocasionalmente

☐ No

¿Existe una Declaración de Aplicabilidad (DoA) ENS aprobada?

• ☐ Sí, para todos los sistemas en alcance

• ☐ Sí, pero solo para algunos sistemas

• ☐ En elaboración

• ☐ No

Indique el estado de implantación de las medidas ENS recogidas en la DoA:

- ☐ ≥ 80 % implantadas
- ☐ 60–79 %
- ☐ 40–59 %
- ☐ < 40 %
- ☐ No se dispone de evaluación consolidada

¿Se realiza seguimiento periódico al cumplimiento de la DoA?

- ☐ Sí, con indicadores y evidencias documentadas
- ☐ Sí, pero de forma cualitativa y no estructurada
- ☐ Ocasionalmente
- ☐ No

2. ANÁLISIS DE RIESGOS, INDICADORES Y CICLO ENS

2.1. Análisis de riesgos

63.

¿La organización dispone de un proceso formal de análisis de riesgos alineado con ENS/NIS2 u otros marcos (ISO 27005, EBIOS, OCTAVE, etc.)?

- ☐ Sí, formalizado y aplicado
- ☐ Sí, pero aplicado de forma parcial o irregular
- ☐ En definición
- ☐ No

64.

Periodicidad del análisis de riesgos sobre sistemas ENS:

- ☐ Anual o más frecuente
- ☐ Cada 2–3 años
- ☐ Sólo ante proyectos o cambios significativos
- ☐ No existe periodicidad establecida

65.

¿Se vinculan explícitamente los resultados de riesgos con la selección de medidas ENS en la DoA?

- ☐ Sí, de manera trazable y documentada
- ☐ Parcialmente
- ☐ Se asume, pero sin trazabilidad clara
- ☐ No

¿La organización dispone de un proceso formal de análisis de riesgos alineado con ENS/NIS2 u otros marcos (ISO 27005, EBIOS, OCTAVE, etc.)?

- ☐ Sí, formalizado y aplicado
- ☐ Sí, pero aplicado de forma parcial o irregular
- ☐ En definición
- ☐ No

Periodicidad del análisis de riesgos sobre sistemas ENS:

- ☐ Anual o más frecuente
- ☐ Cada 2–3 años
- ☐ Sólo ante proyectos o cambios significativos
- ☐ No existe periodicidad establecida

¿Se vinculan explícitamente los resultados de riesgos con la selección de medidas ENS en la DoA?

- ☐ Sí, de manera trazable y documentada
- ☐ Parcialmente
- ☐ Se asume, pero sin trazabilidad clara
- ☐ No

2.2. Informar sobre el Estado de Seguridad (Métricas e Indicadores)

66.

¿La organización dispone de un cuadro de mando de seguridad (KPIs/KRIs) para informar del estado de seguridad a la Alta Dirección?

- ☐ Sí, consolidado y operativo
- ☐ Sí, pero limitado a aspectos técnicos
- ☐ En desarrollo
- ☐ No

67.

¿Con qué frecuencia se presenta formalmente información de estado de seguridad a la Alta Dirección o al órgano de gobierno?

- ☐ Mensual
- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo bajo demanda o tras incidentes
- ☐ No se presenta información estructurada

68.

¿Los indicadores utilizados cubren al menos las siguientes áreas? (puede marcar varias)

- ☐ Cumplimiento ENS / auditorías
- ☐ Gestión de vulnerabilidades
- ☐ Incidentes de ciberseguridad
- ☐ Capacidades de detección y respuesta
- ☐ Formación y concienciación
- ☐ Continuidad y recuperación
- ☐ Riesgo y pérdidas estimadas

¿La organización dispone de un cuadro de mando de seguridad (KPIs/KRIs) para informar del estado de seguridad a la Alta Dirección?

- ☐ Sí, consolidado y operativo
- ☐ Sí, pero limitado a aspectos técnicos
- ☐ En desarrollo
- ☐ No

¿Con qué frecuencia se presenta formalmente información de estado de seguridad a la Alta Dirección o al órgano de gobierno?

- ☐ Mensual
- ☐ Trimestral
- ☐ Semestral
- ☐ Anual
- ☐ Solo bajo demanda o tras incidentes
- ☐ No se presenta información estructurada

¿Los indicadores utilizados cubren al menos las siguientes áreas? (puede marcar varias)

- ☐ Cumplimiento ENS / auditorías
- ☐ Gestión de vulnerabilidades
- ☐ Incidentes de ciberseguridad
- ☐ Capacidades de detección y respuesta
- ☐ Formación y concienciación
- ☐ Continuidad y recuperación
- ☐ Riesgo y pérdidas estimadas

3. CIBERRESILIENCIA SEGÚN IMC (INDICADORES PARA MEJORA DE LA CIBERRESILIENCIA)

3.1. Adopción del modelo IMC

69.

¿La organización conoce y utiliza el modelo IMC (Indicadores para la Mejora de la Ciberresiliencia) de INCIBE?

- ☐ Sí, lo empleamos explícitamente
- ☐ Lo conocemos, pero no lo usamos
- ☐ Lo estamos evaluando para su adopción
- ☐ No lo conocemos

70.

¿En qué medida se han adaptado indicadores IMC a la realidad de la organización?

- ☐ Se han adaptado y desplegado de forma significativa
- ☐ Se han probado en pilotos o servicios concretos
- ☐ Solo se han revisado teóricamente
- ☐ No se han utilizado

¿La organización conoce y utiliza el modelo IMC (Indicadores para la Mejora de la Ciberresiliencia) de INCIBE?

- ☐ Sí, lo empleamos explícitamente
- ☐ Lo conocemos, pero no lo usamos
- ☐ Lo estamos evaluando para su adopción
- ☐ No lo conocemos

¿En qué medida se han adaptado indicadores IMC a la realidad de la organización?

- ☐ Se han adaptado y desplegado de forma significativa
- ☐ Se han probado en pilotos o servicios concretos
- ☐ Solo se han revisado teóricamente
- ☐ No se han utilizado

3.2. Metas de ciberresiliencia (Anticipar, Resistir, Recuperar, Evolucionar)

71.

Para la meta Anticipar (preparación, análisis de amenazas, etc.), ¿existen indicadores que midan la preparación ante ciberataques?

- ☐ Sí, con objetivos cuantitativos claros
- ☐ Sí, pero solo de forma cualitativa
- ☐ En implementación
- ☐ No

72.

Para la meta Resistir (protección, mitigación), ¿cómo calificaría el nivel de indicadores?

- ☐ Amplio catálogo con objetivos y umbrales definidos
- ☐ Catálogo limitado a controles clave
- ☐ Algunos indicadores ad hoc
- ☐ No existen indicadores específicos

73.

Para la meta Recuperar (continuidad, restauración), ¿se miden sistemáticamente los tiempos y la efectividad de recuperación?

- ☐ Sí, mediante indicadores de RTO/RPO, tiempos reales y pruebas
- ☐ Parcialmente, en algunos sistemas críticos
- ☐ De forma esporádica, sin sistemática consolidada
- ☐ No

74.

Para la meta Evolucionar (mejora continua), ¿se emplean indicadores de madurez o progreso de ciberresiliencia?

- ☐ Sí, hay modelo de madurez y seguimiento formal
- ☐ Hay evaluaciones puntuales de madurez
- ☐ Solo apreciaciones cualitativas
- ☐ No

Para la meta **Anticipar** (preparación, análisis de amenazas, etc.), ¿existen indicadores que midan la preparación ante ciberataques?

- ☐ Sí, con objetivos cuantitativos claros
- ☐ Sí, pero solo de forma cualitativa
- ☐ En implementación
- ☐ No

Para la meta **Resistir** (protección, mitigación), ¿cómo calificaría el nivel de indicadores?

- ☐ Amplio catálogo con objetivos y umbrales definidos
- ☐ Catálogo limitado a controles clave
- ☐ Algunos indicadores ad hoc
- ☐ No existen indicadores específicos

Para la meta **Recuperar** (continuidad, restauración), ¿se miden sistemáticamente los tiempos y la efectividad de recuperación?

- ☐ Sí, mediante indicadores de RTO/RPO, tiempos reales y pruebas
- ☐ Parcialmente, en algunos sistemas críticos
- ☐ De forma esporádica, sin sistemática consolidada
- ☐ No

Para la meta **Evolucionar** (mejora continua), ¿se emplean indicadores de madurez o progreso de ciberresiliencia?

- ☐ Sí, hay modelo de madurez y seguimiento formal
- ☐ Hay evaluaciones puntuales de madurez
- ☐ Solo apreciaciones cualitativas
- ☐ No

4. EFICACIA OPERATIVA: KPI/KRI DE CIBERSEGURIDAD

4.1. Gestión de vulnerabilidades

75.

¿Dispone la organización de un proceso de gestión de vulnerabilidades con indicadores formales?

- ☐ Sí, con métricas consolidadas (número, criticidad, tiempo de parcheado, etc.)
- ☐ Sí, pero con métricas limitadas
- ☐ En fase de implantación
- ☐ No

76.

Tiempo medio de parcheado de vulnerabilidades críticas (aproximado):

- ☐ < 7 días
- ☐ 7–30 días
- ☐ 31–90 días
- ☐ > 90 días
- ☐ No medido

¿Dispone la organización de un proceso de gestión de vulnerabilidades con indicadores formales?

- ☐ Sí, con métricas consolidadas (número, criticidad, tiempo de parcheado, etc.)
- ☐ Sí, pero con métricas limitadas
- ☐ En fase de implantación
- ☐ No

Tiempo medio de parcheado de vulnerabilidades críticas (aproximado):

- ☐ < 7 días
- ☐ 7–30 días
- ☐ 31–90 días
- ☐ > 90 días
- ☐ No medido

4.2. Detección y respuesta

77.

¿La organización mide el tiempo medio de detección de incidentes (MTTD)?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero solo para determinados tipos de incidentes
- ☐ No, pero está previsto
- ☐ No

78.

¿Se mide el tiempo medio de respuesta y contención (MTTR)?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero de manera parcial
- ☐ No, pero está previsto
- ☐ No

79.

Indique aproximadamente el nivel actual de MTTD para incidentes significativos:

- ☐ Minutos
- ☐ Horas
- ☐ Días
- ☐ Semanas
- ☐ No se dispone de esta medición

80.

Indique aproximadamente el nivel actual de MTTR para incidentes significativos:

- ☐ Minutos
- ☐ Horas
- ☐ Días
- ☐ Semanas
- ☐ No se dispone de esta medición

¿La organización mide el tiempo medio de detección de incidentes (MTTD)?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero solo para determinados tipos de incidentes
- ☐ No, pero está previsto
- ☐ No

¿Se mide el tiempo medio de respuesta y contención (MTTR)?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero de manera parcial
- ☐ No, pero está previsto
- ☐ No

Indique aproximadamente el nivel actual de MTTR para incidentes significativos:

- ☐ Minutos
- ☐ Horas
- ☐ Días
- ☐ Semanas
- ☐ No se dispone de esta medición

Indique aproximadamente el nivel actual de MTTR para incidentes significativos:

- ☐ Minutos
- ☐ Horas
- ☐ Días
- ☐ Semanas
- ☐ No se dispone de esta medición

4.3. Incidentes de ciberseguridad

81.

¿Se mantiene un registro consolidado de incidentes de ciberseguridad con clasificación por tipo y severidad?

- ☐ Sí, con taxonomía definida y homogénea
- ☐ Sí, pero con cierta heterogeneidad
- ☐ Parcialmente (solo incidentes graves)
- ☐ No

82.

¿Se dispone de indicadores sobre la frecuencia de incidentes significativos por periodo (mensual, trimestral, anual)?

- ☐ Sí, periódicos y revisados por la dirección
- ☐ Sí, pero con uso limitado
- ☐ Ocasionalmente
- ☐ No

83.

¿Se estiman y registran los impactos económicos o de servicio de los incidentes relevantes?

- ☐ Sí, con metodología definida
- ☐ Sí, pero de forma aproximada
- ☐ Sólo en casos excepcionales
- ☐ No

¿Se mantiene un registro consolidado de incidentes de ciberseguridad con clasificación por tipo y severidad?

- ☐ Sí, con taxonomía definida y homogénea
- ☐ Sí, pero con cierta heterogeneidad
- ☐ Parcialmente (solo incidentes graves)
- ☐ No

¿Se dispone de indicadores sobre la frecuencia de incidentes significativos por periodo (mensual, trimestral, anual)?

- ☐ Sí, periódicos y revisados por la dirección
- ☐ Sí, pero con uso limitado
- ☐ Ocasionalmente
- ☐ No

¿Se estiman y registran los impactos económicos o de servicio de los incidentes relevantes?

- ☐ Sí, con metodología definida
- ☐ Sí, pero de forma aproximada
- ☐ Sólo en casos excepcionales
- ☐ No

5. ZERO TRUST Y ARQUITECTURA DE SEGURIDAD

5.1. Adopción del paradigma Zero Trust

84.

¿La organización cuenta con una estrategia o plan de transición hacia un modelo Zero Trust (ZT)?

- ☐ Sí, formalmente definido y en ejecución
- ☐ Sí, como línea de trabajo pero sin plan formal
- ☐ En estudio
- ☐ No

85.

¿Qué elementos de Zero Trust están ya implantados de forma significativa? (marcar los que procedan)

- ☐ Autenticación multifactor para accesos críticos
- ☐ Gestión centralizada de identidades y accesos (IAM/IdP)
- ☐ Segmentación / microsegmentación de redes
- ☐ Control de acceso basado en contexto (usuario, dispositivo, localización, riesgo)
- ☐ Monitorización y registro exhaustivo de accesos entre segmentos
- ☐ Ninguno de los anteriores

¿La organización cuenta con una estrategia o plan de transición hacia un modelo Zero Trust (ZT)?

- ☐ Sí, formalmente definido y en ejecución
- ☐ Sí, como línea de trabajo pero sin plan formal
- ☐ En estudio
- ☐ No

¿Qué elementos de Zero Trust están ya implantados de forma significativa? (marcar los que procedan)

- ☐ Autenticación multifactor para accesos críticos
- ☐ Gestión centralizada de identidades y accesos (IAM/IdP)
- ☐ Segmentación / microsegmentación de redes
- ☐ Control de acceso basado en contexto (usuario, dispositivo, localización, riesgo)
- ☐ Monitorización y registro exhaustivo de accesos entre segmentos
- ☐ Ninguno de los anteriores

5.2. Indicadores de Zero Trust

86.

¿Se dispone de indicadores específicos asociados al despliegue de Zero Trust (porcentaje de recursos protegidos, accesos verificados, etc.)?

- ☐ Sí, con objetivos cuantitativos
- ☐ Sí, pero de forma parcial
- ☐ En definición
- ☐ No

87.

Aproximadamente, ¿qué porcentaje de recursos críticos requieren autenticación multifactor?

- ☐ 0-25 %
- ☐ 26-50 %
- ☐ 51-75 %
- ☐ 76-95 %
- ☐ 96-100 %
- ☐ Se desconoce

88.

¿Se registran y analizan los accesos internos entre segmentos o solo el tráfico perimetral?

- ☐ Ambos (perímetro e intersegmentos)
- ☐ Principalmente el tráfico perimetral
- ☐ Solo registros parciales
- ☐ No se analiza de forma sistemática

¿Se dispone de indicadores específicos asociados al despliegue de Zero Trust (porcentaje de recursos protegidos, accesos verificados, etc.)?

- ☐ Sí, con objetivos cuantitativos
- ☐ Sí, pero de forma parcial
- ☐ En definición
- ☐ No

Aproximadamente, ¿qué porcentaje de recursos críticos requieren autenticación multifactor?

- ☐ 0–25 %
- ☐ 26–50 %
- ☐ 51–75 %
- ☐ 76–95 %
- ☐ 96–100 %
- ☐ Se desconoce

¿Se registran y analizan los accesos internos entre segmentos o solo el tráfico perimetral?

- ☐ Ambos (perímetro e intersegmentos)
- ☐ Principalmente el tráfico perimetral
- ☐ Solo registros parciales
- ☐ No se analiza de forma sistemática

6. FORMACIÓN, CONCIENCIACIÓN Y CULTURA

6.1. Formación y concienciación

89.

¿Existe un plan anual formal de formación y concienciación en ciberseguridad?

- ☐ Sí, planificado y ejecutado
- ☐ Sí, pero de forma informal o ad hoc
- ☐ En diseño
- ☐ No

90.

¿Se registran indicadores de participación y aprovechamiento (porcentaje de personal formado, resultados de pruebas, etc.)?

- ☐ Sí, indicadores cuantitativos consolidados
- ☐ Sí, pero limitados
- ☐ No, aunque se realiza formación
- ☐ No se realiza formación

91.

¿Se realizan campañas de phishing simulado u otras pruebas de comportamiento?

- ☐ Sí, regularmente
- ☐ Sí, de forma puntual
- ☐ No, pero se está valorando
- ☐ No

¿Existe un plan anual formal de formación y concienciación en ciberseguridad?

- ☐ Sí, planificado y ejecutado
- ☐ Sí, pero de forma informal o ad hoc
- ☐ En diseño
- ☐ No

¿Se registran indicadores de participación y aprovechamiento (porcentaje de personal formado, resultados de pruebas, etc.)?

- ☐ Sí, indicadores cuantitativos consolidados
- ☐ Sí, pero limitados
- ☐ No, aunque se realiza formación
- ☐ No se realiza formación

¿Se realizan campañas de phishing simulado u otras pruebas de comportamiento?

- ☐ Sí, regularmente
- ☐ Sí, de forma puntual
- ☐ No, pero se está valorando
- ☐ No

7. CONTINUIDAD, RECUPERACIÓN Y RESILIENCIA OPERATIVA

7.1. Planes de Continuidad y Recuperación

92.

¿La organización dispone de planes formales de continuidad de negocio (BCP) y recuperación ante desastres (DRP) que contemplan incidentes de ciberseguridad?

- ☐ Sí, BCP y DRP específicos
- ☐ Sí, pero solo a nivel TI
- ☐ En elaboración
- ☐ No

93.

¿Con qué frecuencia se prueban los planes (simulacros, ejercicios, pruebas técnicas)?

- ☐ Al menos una vez al año
- ☐ Cada 2–3 años
- ☐ Solo en algunos sistemas
- ☐ No se prueban

94.

¿Se miden y registran los resultados de las pruebas (cumplimiento de RTO/RPO, tiempo real de recuperación, desviaciones)?

- ☐ Sí, sistemáticamente
- ☐ Sí, pero de forma parcial
- ☐ De manera cualitativa
- ☐ No

¿La organización dispone de planes formales de continuidad de negocio (BCP) y recuperación ante desastres (DRP) que contemplan incidentes de ciberseguridad?

- ☐ Sí, BCP y DRP específicos
- ☐ Sí, pero solo a nivel TI
- ☐ En elaboración
- ☐ No

¿Con qué frecuencia se prueban los planes (simulacros, ejercicios, pruebas técnicas)?

- ☐ Al menos una vez al año
- ☐ Cada 2–3 años
- ☐ Solo en algunos sistemas
- ☐ No se prueban

¿Se miden y registran los resultados de las pruebas (cumplimiento de RTO/RPO, tiempo real de recuperación, desviaciones)?

- ☐ Sí, sistemáticamente
- ☐ Sí, pero de forma parcial
- ☐ De manera cualitativa
- ☐ No

8. RIESGO, IMPACTO, IGM Y ROI DE CIBERSEGURIDAD

8.1. Gestión económica del riesgo

95.

¿La organización cuantifica el riesgo cibernético en términos económicos (pérdida esperada, escenarios, etc.)?

- ☐ Sí, con modelos formales (p. ej. FAIR u otros)
- ☐ Sí, con estimaciones internas estructuradas
- ☐ Aproximaciones puntuales sin modelo fijo
- ☐ No

96.

¿Se estima la pérdida anual esperada derivada de incidentes de ciberseguridad?

- ☐ Sí, con revisión periódica
- ☐ Sí, pero con gran incertidumbre
- ☐ Solo en casos de proyectos concretos
- ☐ No

97.

¿Existe ciberseguro contratado?

- ☐ Sí, con coberturas específicas y revisadas
- ☐ Sí, pero poco alineado con la realidad de riesgos
- ☐ No, pero se está evaluando
- ☐ No y no se contempla

¿La organización cuantifica el riesgo cibernético en términos económicos (pérdida esperada, escenarios, etc.)?

- ☐ Sí, con modelos formales (p. ej. FAIR u otros)
- ☐ Sí, con estimaciones internas estructuradas
- ☐ Aproximaciones puntuales sin modelo fijo
- ☐ No

¿Se estima la pérdida anual esperada derivada de incidentes de ciberseguridad?

- ☐ Sí, con revisión periódica
- ☐ Sí, pero con gran incertidumbre
- ☐ Solo en casos de proyectos concretos
- ☐ No

¿Existe ciberseguro contratado?

- ☐ Sí, con coberturas específicas y revisadas
- ☐ Sí, pero poco alineado con la realidad de riesgos
- ☐ No, pero se está evaluando
- ☐ No y no se contempla

8.2. Inversión, IGM y ROI

98.

Aproximadamente, ¿qué porcentaje del presupuesto TI se destina a ciberseguridad (incluyendo personal, tecnología, servicios, seguros)?

- ☐ < 5 %
- ☐ 5–10 %
- ☐ 11–20 %
- ☐ > 20 %
- ☐ No se conoce / no se desglosa

99.

¿Se calculan indicadores de “Grado de Madurez Global” (IGM) u otros índices compuestos de seguridad?

- ☐ Sí, con modelo documentado
- ☐ Sí, pero de forma informal
- ☐ En diseño
- ☐ No

100.

¿Se evalúa el retorno de la inversión (ROI) en ciberseguridad mediante reducción de riesgo, evitación de pérdidas o mejora de resiliencia?

- ☐ Sí, con metodologías internas o externas
- ☐ Sí, pero de manera aproximada
- ☐ No, aunque se reconoce la necesidad
- ☐ No

Aproximadamente, ¿qué porcentaje del presupuesto TI se destina a ciberseguridad (incluyendo personal, tecnología, servicios, seguros)?

- ☐ < 5 %
- ☐ 5–10 %
- ☐ 11–20 %
- ☐ > 20 %
- ☐ No se conoce / no se desglosa

¿Se calculan indicadores de “Grado de Madurez Global” (IGM) u otros índices compuestos de seguridad?

- ☐ Sí, con modelo documentado
- ☐ Sí, pero de forma informal
- ☐ En diseño
- ☐ No

¿Se evalúa el retorno de la inversión (ROI) en ciberseguridad mediante reducción de riesgo, evitación de pérdidas o mejora de resiliencia?

- ☐ Sí, con metodologías internas o externas
- ☐ Sí, pero de manera aproximada
- ☐ No, aunque se reconoce la necesidad
- ☐ No

9. CUMPLIMIENTO NORMATIVO Y ALINEAMIENTO INTERNACIONAL

101.

¿La organización está alineada, además de con ENS, con alguno de los siguientes marcos?

- ☐ ISO/IEC 27001
- ☐ ISO/IEC 27017/27018 u otros específicos
- ☐ NIST CSF
- ☐ Normativa sectorial (DORA, NIS2, Sanidad, etc.)
- ☐ Ninguno de los anteriores

102.

¿Se ha realizado auditoría externa ENS en los últimos 3 años?

- ☐ Sí, con certificación obtenida
- ☐ Sí, sin certificación pero con informe
- ☐ No, pero está planificada
- ☐ No

103.

¿Las conclusiones de auditoría se integran en el cuadro de indicadores de seguimiento?

- ☐ Sí, de manera sistemática
- ☐ Parcialmente
- ☐ Sólo para hallazgos críticos
- ☐ No

¿La organización está alineada, además de con ENS, con alguno de los siguientes marcos?

- ☐ ISO/IEC 27001
- ☐ ISO/IEC 27017/27018 u otros específicos
- ☐ NIST CSF
- ☐ Normativa sectorial (DORA, NIS2, Sanidad, etc.)
- ☐ Ninguno de los anteriores

¿Se ha realizado auditoría externa ENS en los últimos 3 años?

- ☐ Sí, con certificación obtenida
- ☐ Sí, sin certificación pero con informe
- ☐ No, pero está planificada
- ☐ No

¿Las conclusiones de auditoría se integran en el cuadro de indicadores de seguimiento?

- ☐ Sí, de manera sistemática
- ☐ Parcialmente
- ☐ Sólo para hallazgos críticos
- ☐ No

10. PERSPECTIVA DEL RESPONSABLE

104.

En una escala de 1 a 5, ¿hasta qué punto considera que los indicadores actuales reflejan fielmente el riesgo real de la organización?

- ☐ 1 – Muy poco
- ☐ 2 – Poco
- ☐ 3 – Moderadamente
- ☐ 4 – Bastante
- ☐ 5 – Completamente

105.

En una frase, ¿qué indicador le gustaría poder mostrar a la Alta Dirección y hoy no puede medir adecuadamente?

Respuesta abierta: _____

106.

¿Hay algo más que quiera añadir sobre la medición de la ciberseguridad y la ciberresiliencia en su organización?

Respuesta abierta: _____

En una escala de 1 a 5, ¿hasta qué punto considera que los indicadores actuales reflejan fielmente el riesgo real de la organización?

- ☐ 1 – Muy poco
- ☐ 2 – Poco
- ☐ 3 – Moderadamente
- ☐ 4 – Bastante
- ☐ 5 – Completamente

En una frase, ¿qué indicador le gustaría poder mostrar a la Alta Dirección y hoy no puede medir adecuadamente?

- Respuesta abierta: _____

¿Hay algo más que quiera añadir sobre la medición de la ciberseguridad y la ciberresiliencia en su organización?

- Respuesta abierta: _____

Gracias por participar. Las cifras pueden ser ingratas, pero son más fiables que la fe. Y, a diferencia de los incidentes, no muerden.